HIGH-LEVEL DESIGN · SOLUTION ARCHITECTURE

CAF Compliance ServiceNow ⇄ Salesforce

Project architecture and solution high-level design, including the bi-directional integration between the ServiceNow compliance engine and the Salesforce engagement layer.

ServiceNow · system of record ⇄ Salesforce · engagement layer

Document	Solution High-Level Design (HLD)
Version	1.0
Date	22 October 2026
Source baseline	caf-sf-integration · main @ 571386c
ServiceNow scope	x_gskn2_caf_compli v1.0.0
Salesforce API	v67.0

Contents

1. Executive summary
2. Scope and objectives
3. Solution context
4. Architecture principles
5. Logical architecture
6. Bi-directional integration design
7. Integration sequence flows
8. Data architecture
9. Process and state model
10. Security architecture
11. Non-functional design
12. Deployment and environments
13. Testing and assurance
14. Key design decisions
15. Risks, limitations and roadmap
16. Glossary

1. Executive summary

CAF Compliance keeps critical business applications provably compliant against a catalogue of controls (high availability, backup and restore, disaster recovery, RTO/RPO and similar). Controls generate recurring **requests** per business application; requests break down into **tasks**; owners gather **evidence**; approvers **attest**; anything overdue drops out of compliance automatically.

The compliance engine — data model, state machine, recurrence, scheduled jobs, approvals and security — runs in **ServiceNow**. The people who do the work (application owners and approvers) already live in **Salesforce**. This solution surfaces the full compliance experience in Salesforce without moving any state out of ServiceNow.

Governing rule: ServiceNow is the system of record. Salesforce holds a mirror, never a second opinion.

The two platforms are joined by a **bi-directional integration**:

- **Outbound (ServiceNow → Salesforce): state.** Async business rules push requests, tasks and the control catalogue into Salesforce, upserting by the ServiceNow `sys_id`.
- **Inbound (Salesforce → ServiceNow): intentions.** Salesforce calls a six-resource Scripted REST API to start tasks, upload evidence, attest, read a snapshot and request a re-sync. ServiceNow applies its own rules, then pushes the resulting state back.
- **Assurance.** A Sync Health panel detects drift between the two systems and offers per-record repair; every Salesforce callout is logged durably.

Business drivers

Driver	Outcome
Licensing	App owners and approvers work in Salesforce, avoiding a ServiceNow fulfiller licence per person.
Adoption	Low portal adoption was a named risk; compliance work now appears where users already spend their day.
Low delivery risk	Zero change to the 24 business rules, 2 flows, recurrence logic and security model in ServiceNow.

2. Scope and objectives

In scope

- Mirroring CAF Requests, CAF Tasks and the CAF Control catalogue into Salesforce
- Salesforce compliance grid, drill-in, Approvals, Reports and Admin screens
- Evidence upload to both platforms; attestation from Salesforce
- Inbound Scripted REST API with write allow-list and evidence gate
- Drift detection and manual repair (Sync Health)
- Durable callout logging and externalised configuration

Out of scope (this release)

- Moving any state machine or scheduler logic into Salesforce
- Mirroring relationships, task templates or CMDB records
- Experience Cloud site for external users
- Named approver records (`sysapproval_approver`)
- Queued/asynchronous inbound calls and automatic retry
- Row-level security across the integration seam

Objectives

1. Give application owners a single Salesforce screen that answers "is my application compliant, and what do I do next?".
2. Guarantee that every state change is decided by ServiceNow rules, regardless of where the user clicked.
3. Make any disagreement between the two platforms visible within one check, and repairable by one click.
4. Keep the integration replay-safe, so failures can be repaired by re-pushing without creating duplicates.

3. Solution context

The context diagram shows who uses the solution and which systems it touches. Business users work only in Salesforce; administrators and auditors keep the ServiceNow native UI and `/caf` portal.

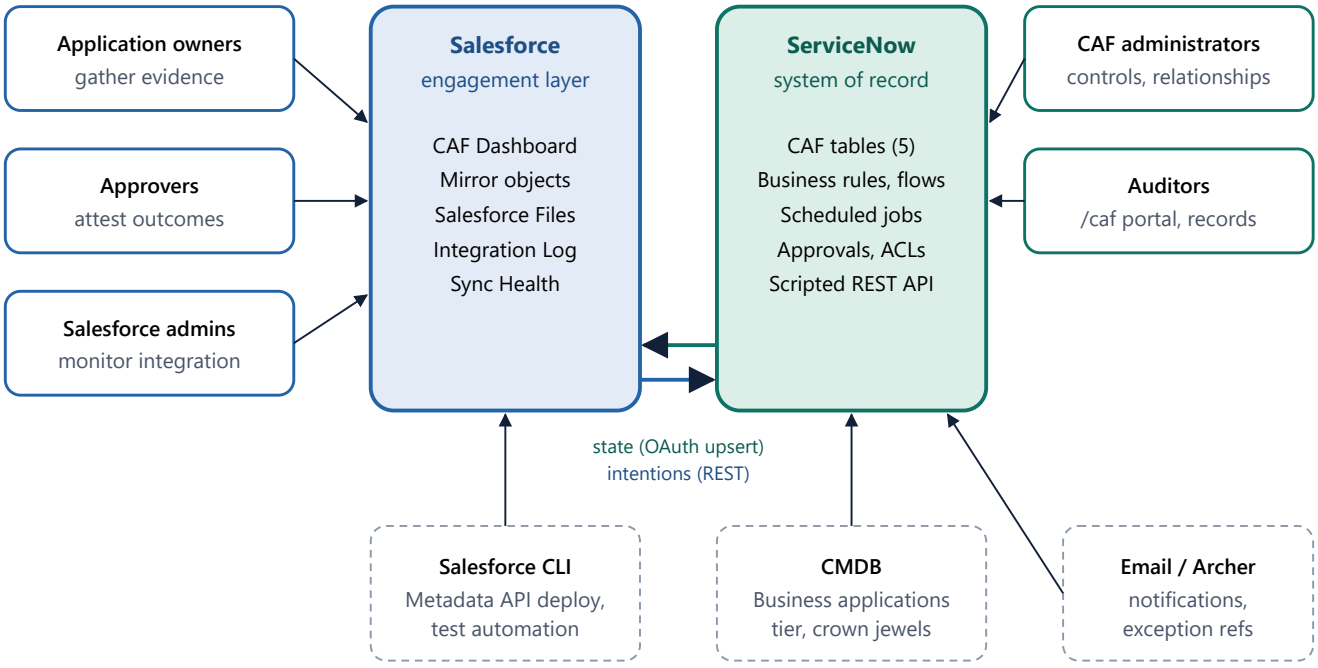


Figure 1 · System context

4. Architecture principles

#	Principle	Implication
P1	Single system of record	All state transitions, recurrence and approvals execute in ServiceNow. Salesforce never edits a value ServiceNow owns.
P2	Mirror, don't replicate configuration	Only requests, tasks and the control catalogue are mirrored. Relationships and templates remain in one place.
P3	Intentions in, state out	Salesforce asks ("start this task"); ServiceNow decides and pushes the result back.
P4	Replay-safe by design	All outbound writes are upserts by External Id; re-pushing a record never duplicates it.
P5	Never block a compliance write	Outbound pushes are async and after commit; a Salesforce outage cannot roll back ServiceNow.
P6	Fail loudly, never partially	The inbound allow-list rejects the whole call if any field is not writable.
P7	Detect automatically, repair deliberately	Drift is detected on every check; repair is a button a person presses, and only flows ServiceNow → Salesforce.
P8	Data-driven UI	Grid columns come from the control catalogue; adding a control needs no code change.

5. Logical architecture

The solution is two platforms joined by a narrow seam. Each side is layered; the seam has exactly two channels, one per direction.

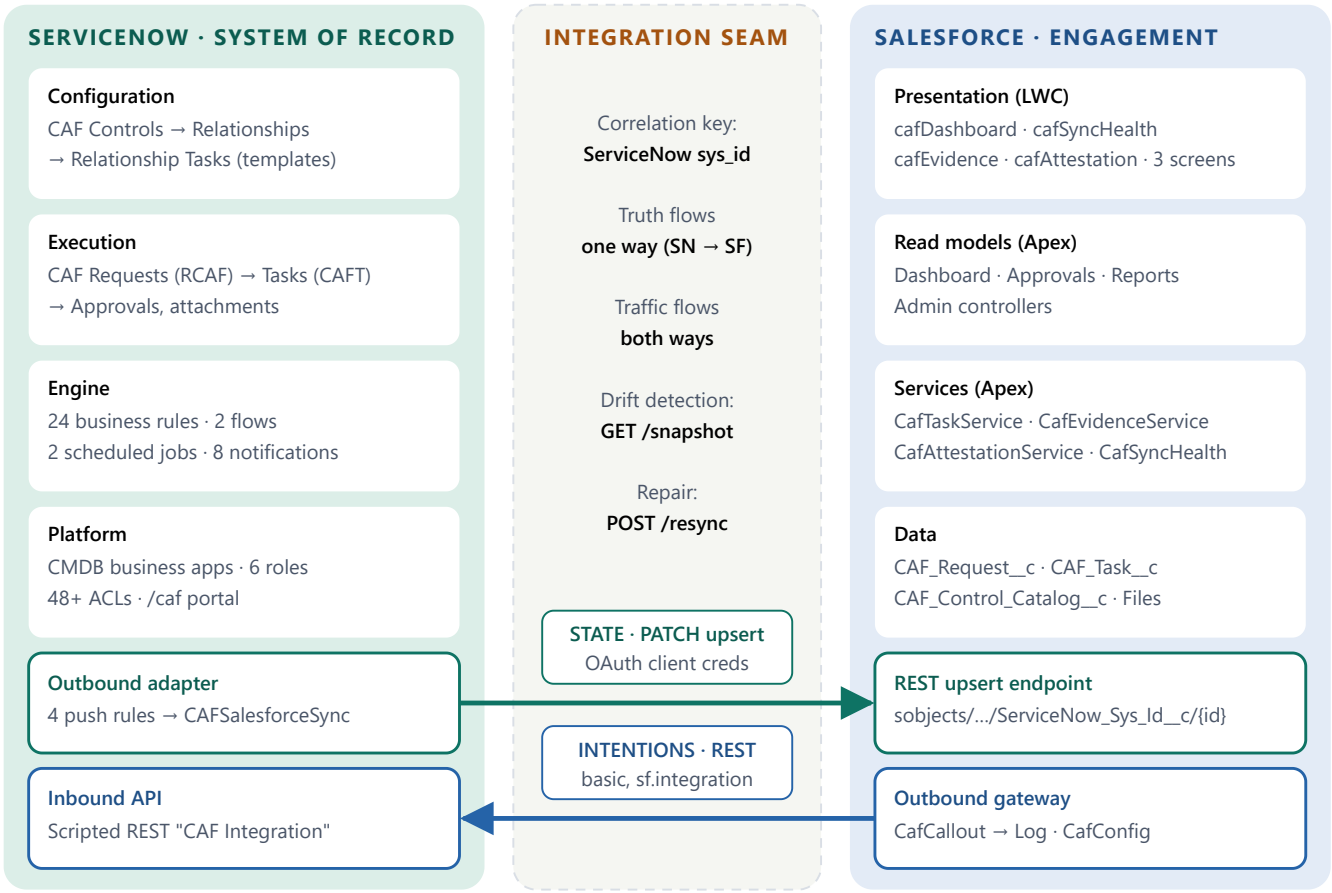


Figure 2 · Logical architecture and the integration seam

5.1 Component responsibilities

Component	Platform	Responsibility
CAF tables (5)	ServiceNow	Controls, relationships, relationship tasks, requests and tasks — the system of record.
Business rules, flows, jobs	ServiceNow	Generate requests and tasks, close requests, detect overdue, transition on approval.
`CAFSalesforceSync`	ServiceNow	Builds payloads, obtains OAuth token, upserts into Salesforce. Methods: pushRequest, pushTask, pushControl, retireControl.
Scripted REST "CAF Integration"	ServiceNow	Six inbound resources; enforces the allow-list and evidence gate; reconciles explicitly after each write.
`CafTaskService`	Salesforce	Task list for the drill-in; `applyChange` PATCHes a task in ServiceNow.
`CafEvidenceService`	Salesforce	Lists files on both sides; pushes a Salesforce File to ServiceNow as an attachment.
`CafAttestationService`	Salesforce	Sends the attestation outcome; returns ServiceNow's verdict.

Component	Platform	Responsibility
`CafSyncHealth`	Salesforce	Compares snapshot to mirror; reports differences; triggers single-record resync.
`CafCallout` + event trigger	Salesforce	Single callout gateway; times every call and logs it via a platform event.
`CafConfig` + `CAF_Setting__mdt`	Salesforce	Task path, evidence cap, timeout and logging switch, changeable without deploy.
Screen controllers (4)	Salesforce	Read models for Compliance, Approvals, Reports and Admin.

6. Bi-directional integration design

The integration is bi-directional in traffic but one-directional in truth. Figure 3 shows every channel, its trigger, its authentication and its target.

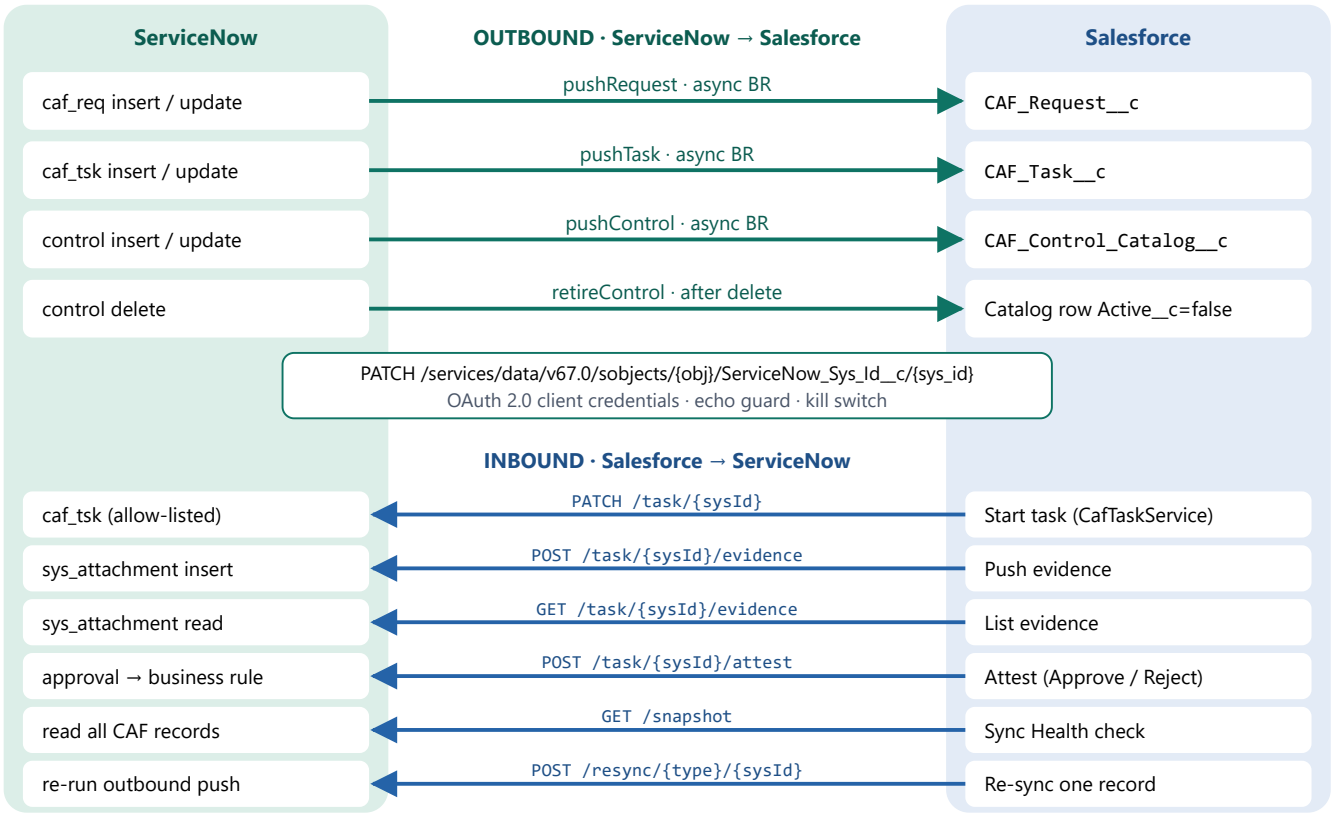


Figure 3 · Bi-directional integration channels. Inbound base path: /api/x_gskn2_caf_compli/caf · authenticated as sf.integration via the ServiceNow_CAF named credential.

6.1 Outbound: ServiceNow → Salesforce

Business rule	Table	When	Calls
CAF - Push Request to Salesforce	caf_req	async, ins/upd	pushRequest
CAF - Push Task to Salesforce	caf_tsk	async, ins/upd	pushTask
CAF - Push Control to Salesforce	caf_conformance_type	async, ins/upd	pushControl
CAF - Retire Control in Salesforce	caf_conformance_type	after delete	retireControl

Every rule carries the **echo-loop guard** in its condition: `gs.getUserName() != sf.integration_user`. Pushes are fire-and-forget — a failure is logged with `gs.error` and never rolls back the ServiceNow transaction.

Configuration (system properties, prefix `x_gskn2_caf_compli.sf.`)

Property	Purpose
enabled	Master kill switch. `false` stops all pushes; nothing is queued.
instance_url	Salesforce My Domain URL, for token and data API.

Property	Purpose
api_version	Salesforce REST API version (v67.0).
client_id / client_secret	Connected app credentials; secret stored encrypted (password2).
integration_user	User name inbound writes arrive as; the echo guard keys off it.

6.2 Inbound: Salesforce → ServiceNow

One Scripted REST API, six resources, all authenticated. The generic update accepts only an allow-list of six fields:

`state · met_criteria · approval · comments · vqd_link · vqd_link_2`

> Any field outside the allow-list fails the **whole** call with HTTP 400 and nothing is applied. A partial write the caller cannot see is worse than an error.

Code	Meaning
200	Update or attestation applied
201	Evidence stored as a sys_attachment
400	Empty body, non-allow-listed field, invalid outcome or criteria
404	No CAF Task with that sys_id
409	Task not In Progress, no longer active, or outcome already recorded
428	Evidence gate: no attachment on the task

6.3 Echo-loop guard and explicit reconcile

The echo guard stops a Salesforce-originated change bouncing straight back. On its own it also **strands derived changes**: cascading rules (for example a task moving its parent request to In Progress) run in the same transaction as the same user, so their pushes are skipped too.

The fix: every inbound resource ends with an **explicit reconcile** — exactly two upserts, the task and its parent request — triggered by the API request rather than a record change, so no loop can form. A healthy round trip logs one `[SF->CAF]` line followed by two `[CAF->SF]` lines.

> Do not simplify the reconcile away. Its failure is silent: the mirror simply stops matching, and only Sync Health notices.

7. Integration sequence flows

Each diagram shows Salesforce participants on a blue lane and ServiceNow participants on a green lane. Solid arrows are calls; dashed arrows are responses.

7.1 Outbound record push (ServiceNow → Salesforce)

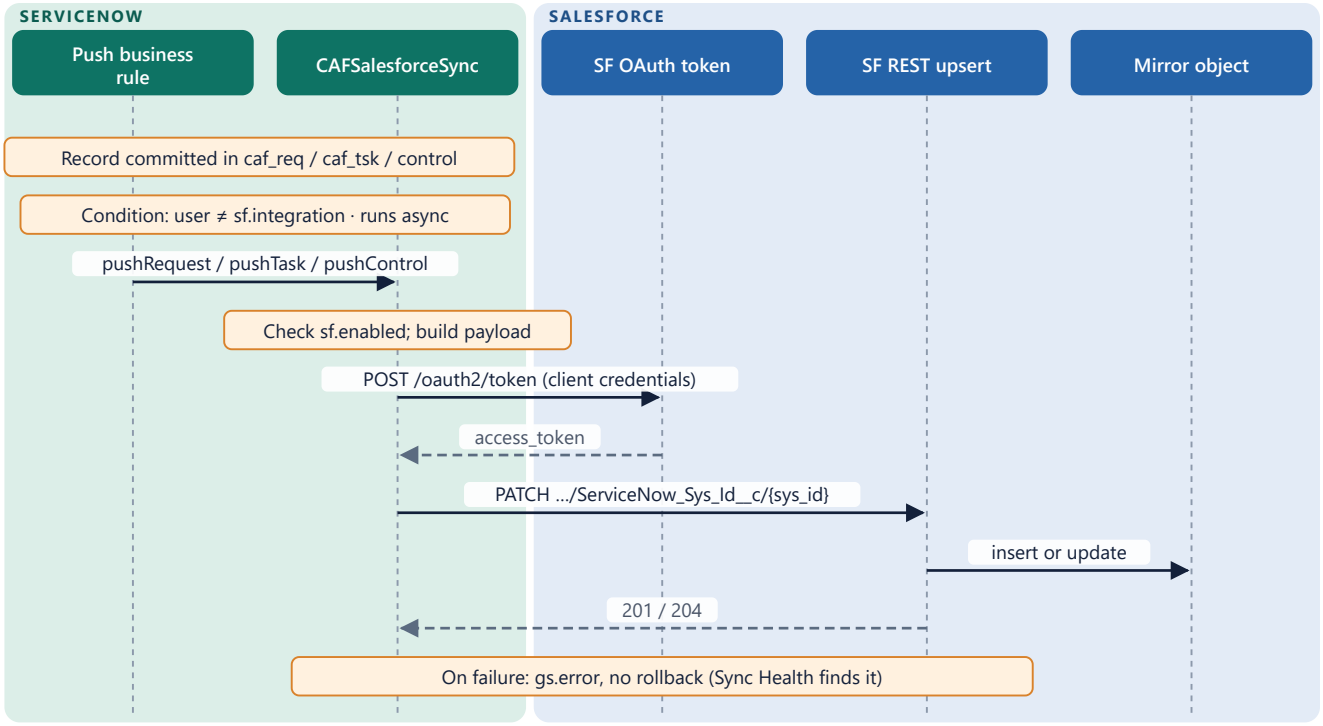


Figure 8 · Outbound push

7.2 Start a task (inbound write with explicit reconcile)

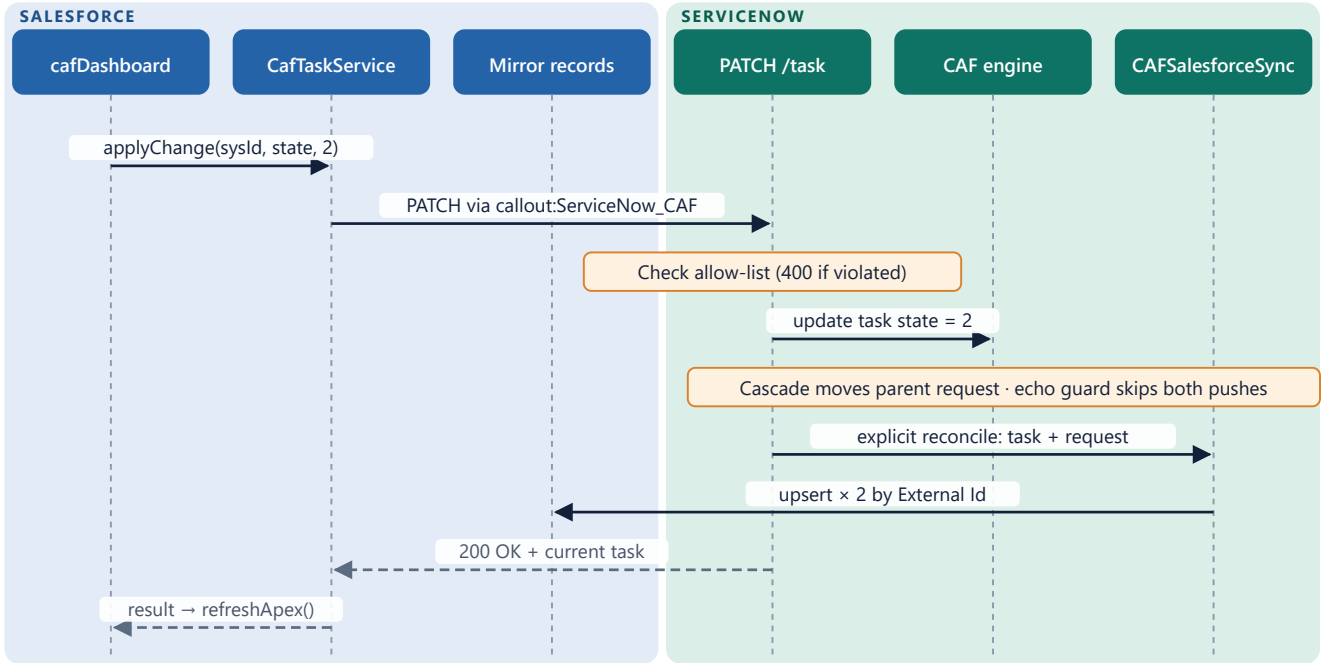


Figure 9 · Start a task

7.3 Upload evidence

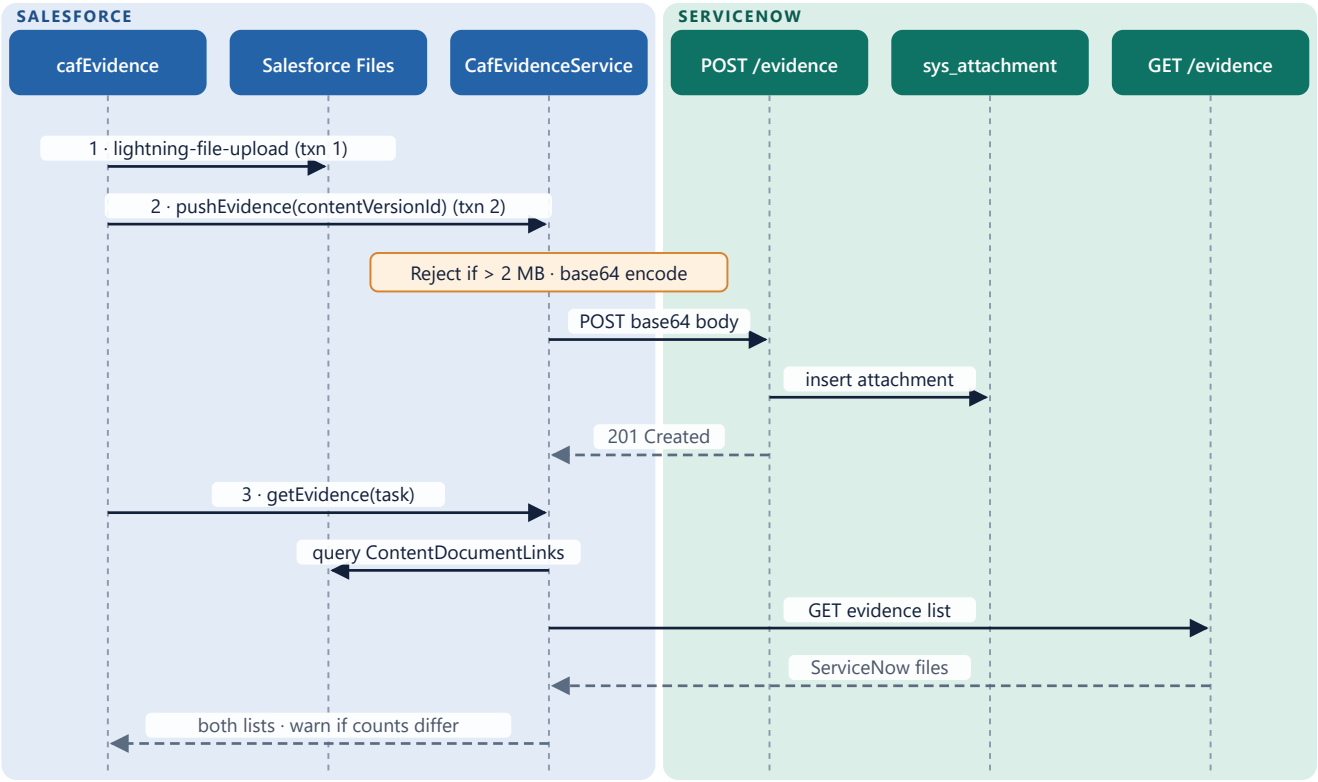


Figure 10 · Upload evidence

Upload and push are two Apex transactions because Apex cannot call out after uncommitted DML. Files are capped at 2 MB: Apex holds the blob and its base64 copy in the same 6 MB heap.

7.4 Attest a task

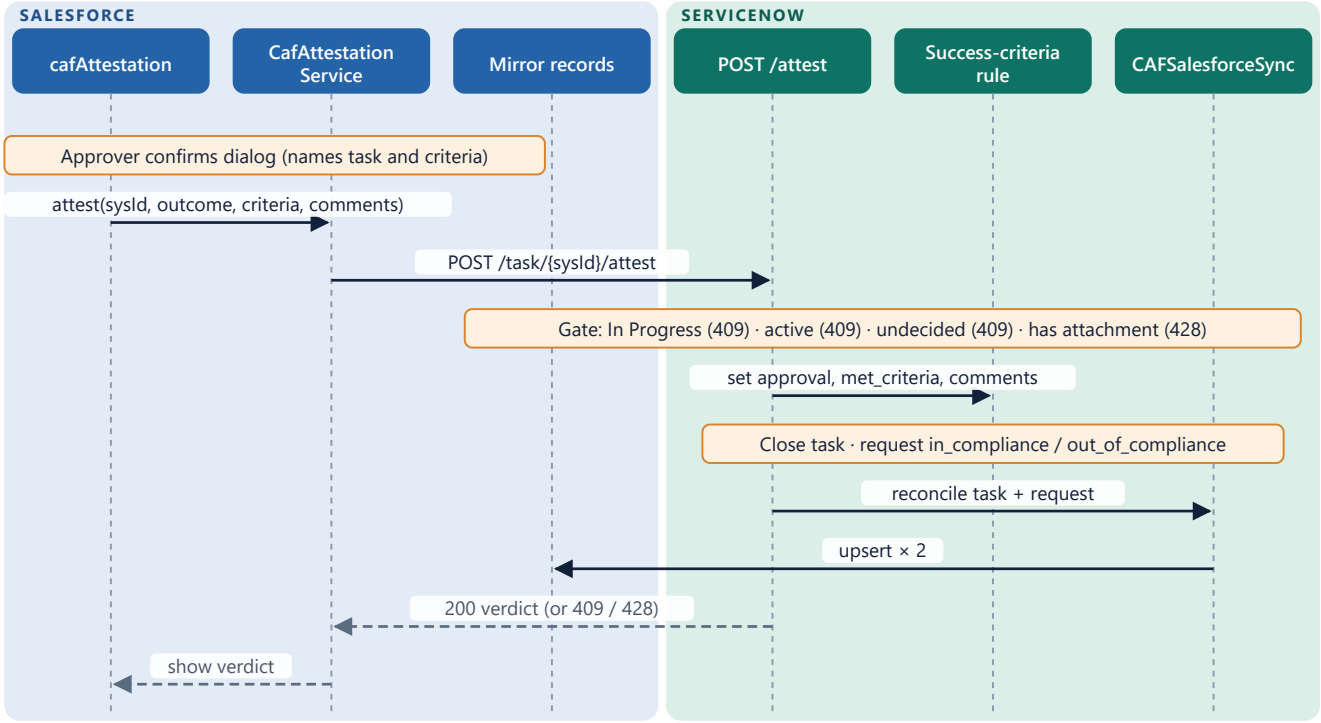


Figure 11 · Attest a task

The endpoint enforces the gate and writes three fields; the existing ServiceNow business rule *CAF - success criteria not met* performs the transition. The transition is not reimplemented, so the `/caf` portal and Salesforce share one rule.

7.5 Sync Health check and repair

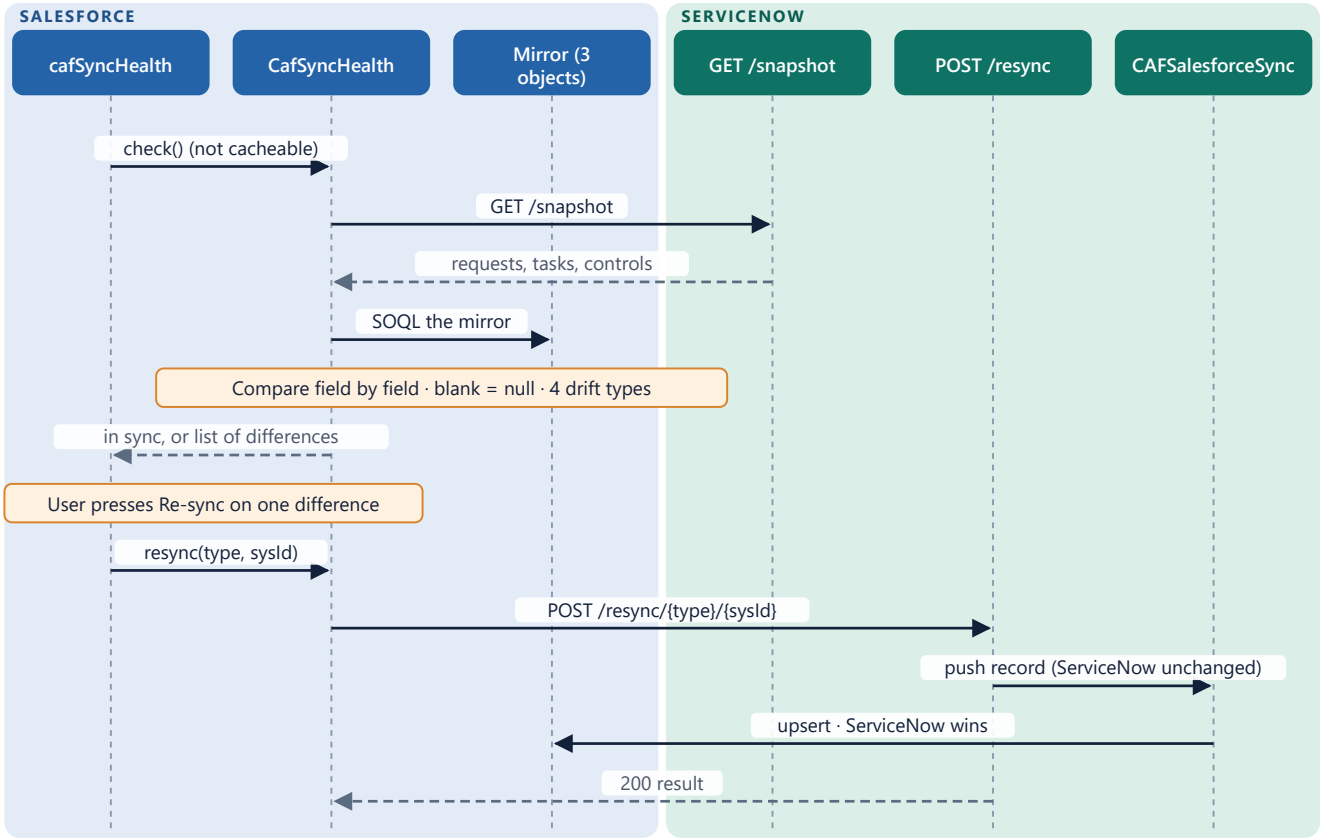


Figure 12 · Sync Health check and repair

7.6 Callout logging (Salesforce)

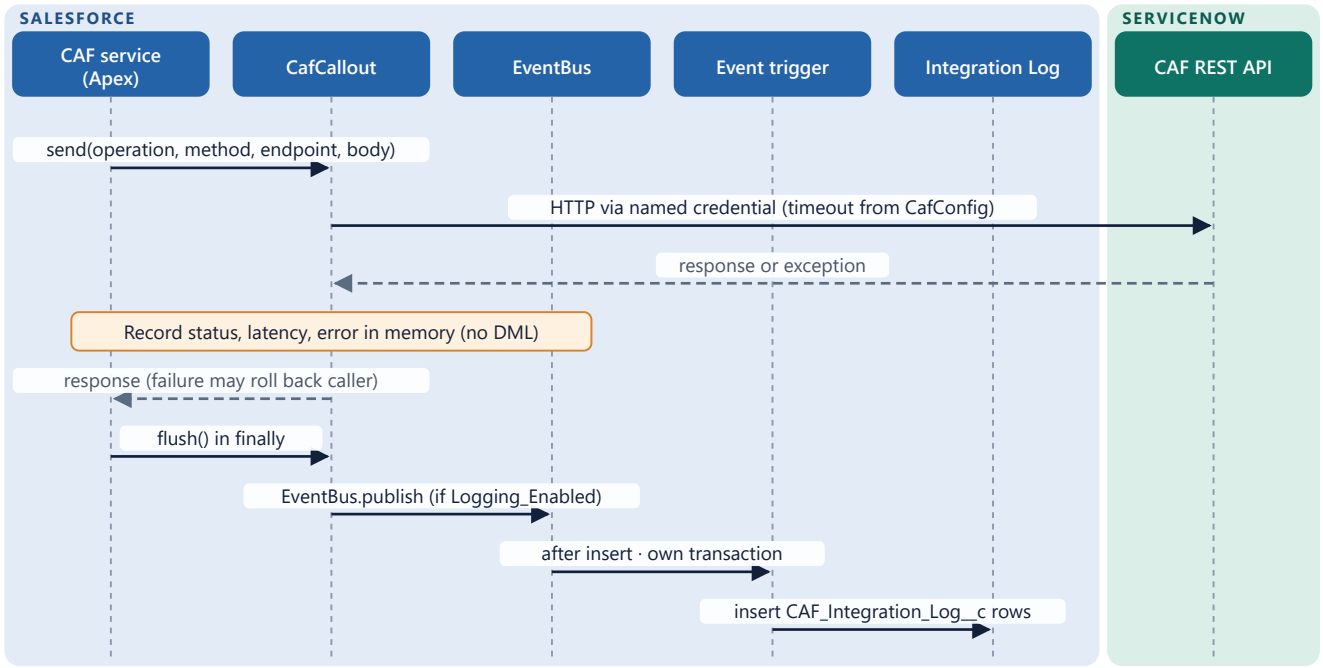


Figure 13 · Callout logging

Logging uses the `CAF_Callout_Event__e` platform event so the log row survives when the caller's transaction rolls back, and so no DML happens between two callouts.

8. Data architecture

Five ServiceNow tables form the data model. Three are mirrored into Salesforce; two remain configuration-only.

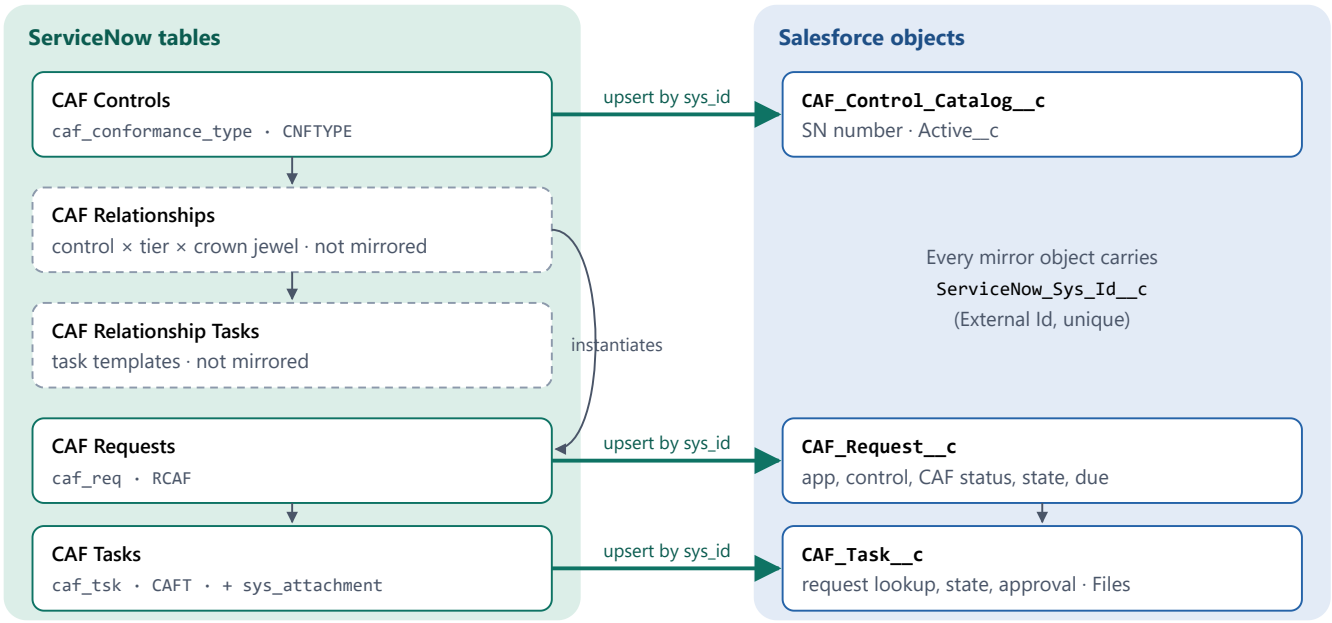


Figure 4 · Data model and mirroring

8.1 Mirrored field mapping

ServiceNow (caf_req / caf_tsk)	Salesforce	Notes
sys_id	ServiceNow_Sys_Id__c	External Id, unique — the correlation key
number	Name, SN_Number__c	RCAF… / CAFT…
short_description	Short_Description__c	Truncated to 255
business_application	Business_Application__c	Display value; CMDB is not mirrored
caf_conformance_type → control	CAF_Control__c, CAF_Control_Sys_Id__c	Resolved two hops via relationship; sys_id is the join key
caf_status	CAF_Status__c	in_compliance · approaching_due · out_of_compliance · archer_exception_approved
state (1, 2, 3, −1)	State__c	Label: Open · In Progress · Closed Complete · Cancelled
planned_completion_date	Planned_Completion_Date__c	Converted to ISO date-time
approval, met_criteria (task)	Approval__c, Met_Criteria__c	requested / approved / rejected · yes / no
parent (task)	CAF_Request__c lookup	Parented by External Id, not by Salesforce Id

8.2 Correlation and lifecycle rules

- **One-directional correlation.** No Salesforce Id is stored in ServiceNow. A rebuilt Salesforce org repopulates by re-pushing.
- **Deletes do not propagate**, except a deleted control is mirrored as `Active__c = false` so its grid column disappears.
- **Evidence is held twice, deliberately.** Salesforce Files serve preview and download; the ServiceNow attachment is the auditor's copy and the only one the attestation gate counts.
- **Salesforce-only objects:** `CAF_Integration_Log__c`, `CAF_Callout_Event__e`, `CAF_Setting__mdt`.

9. Process and state model

9.1 End-to-end compliance process

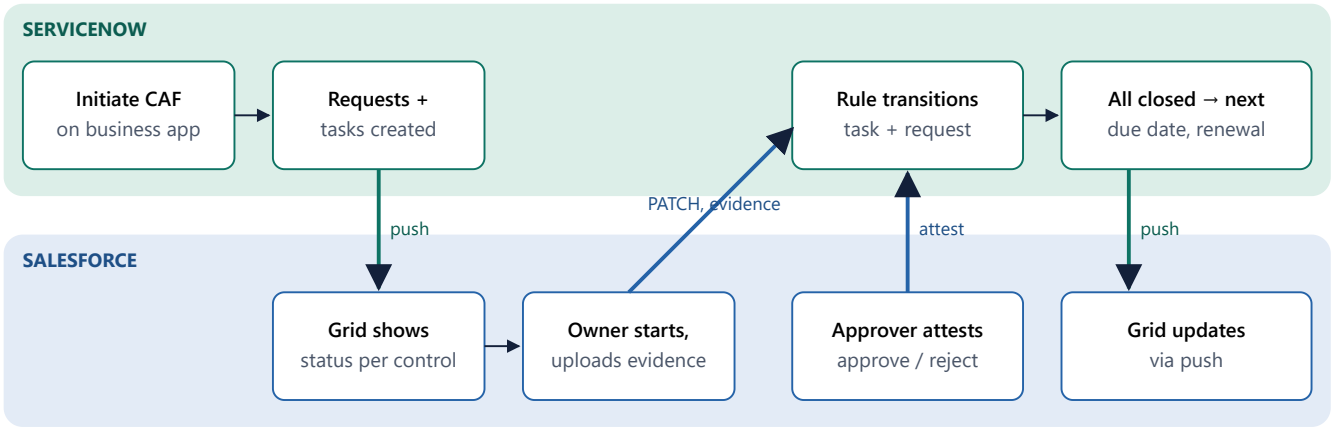


Figure 5 · Compliance process across both platforms

9.2 Task state model and Salesforce actions

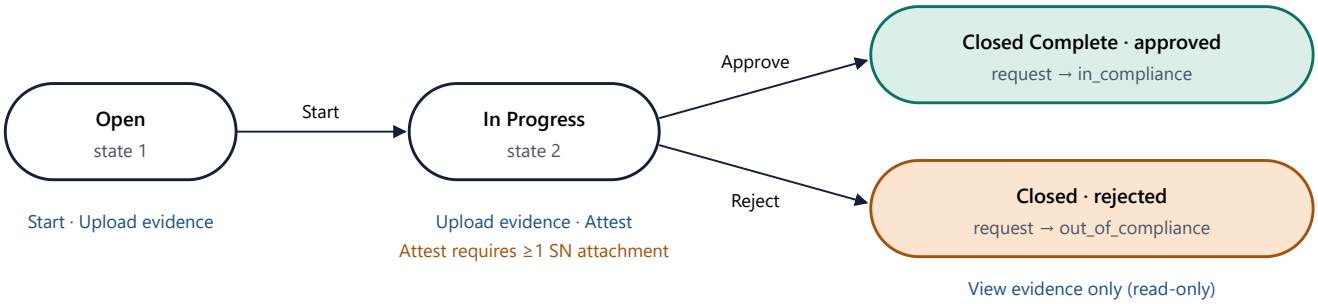


Figure 6 · Task states (decided in ServiceNow) and the Salesforce actions offered in each

Closing the last task on a request does not necessarily close the request — the ServiceNow flow may create the next task in the chain. An overdue request is moved out of compliance by the daily scheduled job, independently of user action.

10. Security architecture

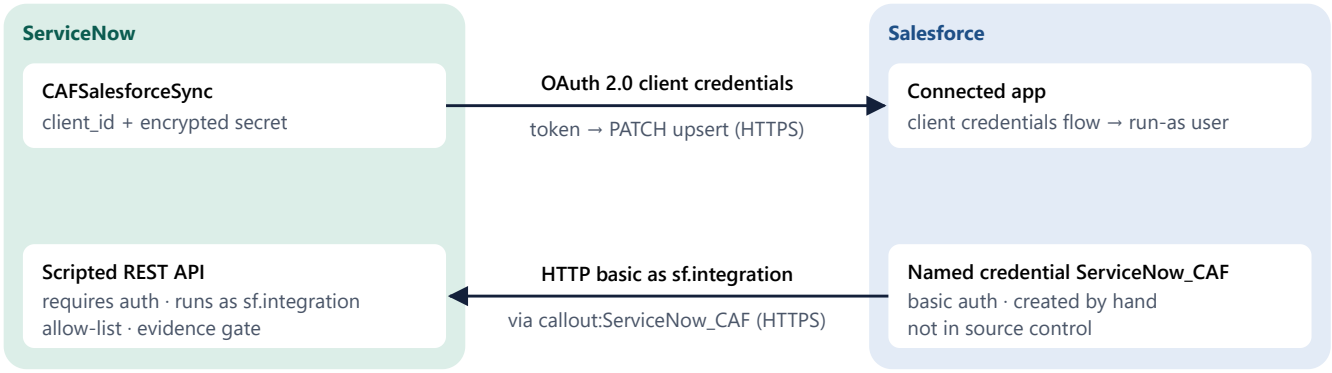


Figure 7 · Authentication in each direction

Control	Design
Outbound authentication	OAuth 2.0 client credentials; secret stored as an encrypted `password2` property.
Inbound authentication	HTTP basic as the dedicated `sf.integration` user through the `ServiceNow_CAF` named credential.
Least privilege (inbound)	Six-field allow-list; all-or-nothing rejection; state checks (409) and evidence gate (428).
Salesforce permissions	`CAF_Integration` : objects, field-level security, Apex classes, tabs. `CAF_Admin` : adds read on the integration log.
Mirror integrity	Mirrored fields are read-only on layouts; Salesforce changes state only by asking ServiceNow.
ServiceNow roles	6 roles (admin, engineer, three tier owners, read-only), 48+ ACLs, query business rules for row-level security.
Secrets handling	No credential in source. The named credential password is set in Setup; test automation reuses the CLI's OAuth grant.

> The echo-loop guard keys off the user name. Running the inbound API as any other account silently disables the guard and creates a push loop.

11. Non-functional design

Quality	Design response
Reliability	Outbound pushes async after commit; inbound calls synchronous with clear status codes; idempotent upserts allow safe replay.
Consistency	Explicit reconcile after every inbound write; Sync Health compares 3 record types field by field (blank treated as null) and flags checks older than 15 minutes.
Observability	Every Salesforce callout logged to `CAF_Integration_Log__c` (operation, status, latency, error, user). ServiceNow logs `[SF->CAF]` / `[CAF->SF]` lines. Admin screen shows success rate and latency.
Performance limits	Evidence ≤ 2 MB per file (6 MB Apex heap); callout timeout 120 s; one file per Apex transaction.
Capacity	Salesforce Developer Edition: 15,000 inbound API requests per day; one end-to-end journey costs roughly 45. Current data: 463 requests, 496 tasks, 6 controls, 77 applications.
Configurability	`CAF_Setting__mdt` (task path, evidence cap, timeout, logging) and ServiceNow `sf.*` properties, including a kill switch.
Extensibility	New controls appear as grid columns with no code change; LWCs carry record-page and Experience Cloud targets.
Recoverability	Salesforce org can be rebuilt and repopulated by re-push; single-record Re-sync for drift.

12. Deployment and environments

Platform	Environment	Deployment method
ServiceNow	PDI dev249570 · scope x_gskn2_caf_compli	Scripted rebuild from source: `servicenow/deploy/01–10` (app, roles, tables, fields, choices, properties, navigation, seed data, code).
Salesforce	Developer Edition orgfarm-4938c7f768 · API v67.0	Metadata API deploy of `salesforce/force-app` via the `sf` CLI (alias `caf-sf`).
Manual steps	Both	Named credential `ServiceNow_CAF`; connected app for client credentials; permission-set assignment.

Repository structure

Path	Contents
salesforce/force-app	Apex (classes, tests, trigger), 9 LWCs, objects, metadata, layouts, permission sets, tabs
salesforce/test/lwc	Jest unit tests for LWCs
servicenow/	Push business rules, Scripted REST resources, script includes, deploy scripts
testing/	Test case catalogues, Playwright automation, evidence generator and packs
presentation/	Business, technical and plain-English decks

13. Testing and assurance

Level	Volume	Approach
Apex unit tests	9 test classes	Every service and controller; mocked callouts; shared `CafTestSupport` fixtures.
Offline unit tests	115 cases	Jest suites for 7 LWCs plus harness preflight; no org required.
Integration (E2E)	70 cases	Playwright drives Salesforce and verifies ServiceNow records.
ServiceNow	69 cases	Engine, native UI and /caf portal.

Every end-to-end case records **two proofs**: what the screen showed and what the record holds. Results are merged with the case definitions into branded Word evidence records, so a document cannot claim a result the specification does not contain.

14. Key design decisions

ID	Decision	Rationale
D1	State machine stays in ServiceNow	One scheduler, one truth, one audit trail.
D2	Mirror only requests, tasks, controls	Configuration stays in one place.
D3	Upsert by External Id on sys_id	Replay-safe; org rebuild survivable.
D4	No Salesforce Id stored in ServiceNow	One-directional correlation; orphans on delete are the cheaper problem.
D5	Async, fire-and-forget push	A Salesforce outage never rolls back a compliance write.
D6	Echo guard plus explicit reconcile	The guard alone strands derived changes, silently.
D7	Allow-list rejects the whole call	No invisible partial writes.
D8	Detection automatic, repair manual, SN → SF only	Unattended repair can spread a problem; a disagreeing mirror is stale by definition.
D9	Evidence gate in the attest endpoint	Portal closure behaviour unchanged; pre-existing tasks unaffected.
D10	Attestation reuses the existing business rule	One transition shared by portal and Salesforce.
D11	Callout log via platform event	Log survives rollback; no DML between callouts.
D12	Client credentials rather than JWT	ServiceNow JWT provider lacks required claims without custom script; JWT is the production target.

15. Risks, limitations and roadmap

Limitation / risk	Impact	Mitigation / next step
No named approver	Audit trail records only sf.integration; approval notification never fires	Create `sysapproval_approver` records with the Salesforce user
Synchronous inbound calls	ServiceNow outage fails the user action; no retry	Queue intentions (platform events / queueable) with retry
Sync Health on demand only	Drift waits until someone looks	Scheduled nightly check with alerting
No Experience Cloud site	Licensing benefit not fully realised	Verify licences; place existing LWCs on a site
Client credentials auth	Acceptable for POC, weaker for production	Move outbound to JWT bearer
Row-level security deferred	All mirrored rows visible to permitted users	Sharing rules by application owner
Fire-and-forget push	Failed push visible only via Sync Health / logs	Scheduled Sync Health; alert on failure count
Echo guard bound to user name	Misconfigured user causes loop and API burn	Preflight check of integration user; monitor API usage

16. Glossary

Term	Meaning
CAF	The compliance assurance framework: controls, requests, tasks and attestation.
Control	A compliance requirement, e.g. "Test Backup & Restore" (CNFTYPE…).
Request (RCAF)	One control applied to one business application for one cycle.
Task (CAFT)	A unit of work under a request, with success criteria and approval.
Attestation	An approver's approve/reject decision on a task, based on evidence.
Mirror	Salesforce's read-only copy of ServiceNow records.
Drift	Any disagreement between a ServiceNow record and its mirror.
Echo-loop guard	Business rule condition that skips pushes for writes made by sf.integration.
Reconcile	The explicit two-record push at the end of each inbound write.
Upsert	Insert-or-update keyed on an External Id.